

Security Model for Cloud Database as a Service (DBaaS)

Kashif Munir[†]

King Fahd University of Petroleum & Minerals, Saudi Arabia

Email : kashifmr@kfupm.edu.sa

Abstract - Database-as-a-service (DBaaS) is a cloud computing service model that provides users with some form of access to a database without the need for setting up physical hardware, installing software or configuring for performance. Since consumers host data on the Cloud, DBaaS providers should be able to guarantee data owners that their data would be protected from all potential security threats. Protecting application data for large-scale web and mobile apps can be complex; especially with distributed and NoSQL databases. Data centers are no longer confined to the enterprise perimeter. More and more enterprises take their data to the cloud, but forget to adjust their security management practices when doing so. Unauthorized access to data resources, misuse of data stored on third party platform, data confidentiality, integrity and availability are some of the major security challenges that ail this nascent Cloud service model, which hinders the wide-scale adoption of DBaaS. In this paper, I propose a security model for cloud Database as a service (DBaaS). A user can change his/her password, whenever demanded. Furthermore, security analysis realizes the feasibility of the proposed framework for DBaaS and achieves efficiency. This will help Cloud community to get an insight into state-of-the-art progress in terms of secure strategies, their deficiencies and possible future directions.

Keywords: Cloud databases, Database as a Service, NoSQL, big data, Database security, DBaaS

I. INTRODUCTION

DBaaS provides automated services where consumers can request database-oriented functionalities from a dedicated service hosted on Cloud. The model is end user driven and provides self-service provisioning. It is based on architectural and operational approach [1] which provides new and distinctive ways of using and managing database services. There are many other database services which are available today but DBaaS differs from those traditional databases because its architecture has two major attributes [1]: Service-orientated as database facilities are available in the form of service. Customer self-service interaction model as organizations are allowed to use, configure and deploy the Cloud database services themselves without any IT support and without purchasing any hardware for specified purpose. These are the three main phases in the overall DBaaS architecture as depicted in Figure 1.

- i. Consumers request the database deployment via Cloud.
- ii. Consumers adjust the capacity as demand changes.
- iii. Consumers can retire from the app when not needed.

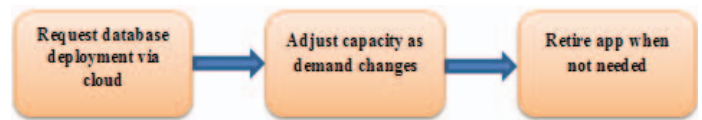


Figure 1. Cloud DBaaS [2]

L. Ferretti [3] et al. advised against using any intermediary component for accessing the database on behalf of the clients, since it becomes a single point of failure. Security and availability of DBaaS services are bounded by this trusted intermediary proxy server.

C. Wang et al. [4] proposed a similar approach which puts forth an idea of using third party auditors. This approach is suitable for preserving data integrity when data is outsourced to the DBaaS providers and users get access on-demand high quality services without facing maintenance burden of local data storage.

R. Nithiavathy [5] proposed integrity auditing mechanism that utilizes distributed erasure-coded data for employing redundancy and homomorphic token. This technique allows third party auditors and users to audit their logs and events at Cloud storage using light weight communication protocol at less computation cost.

Q Zheng et al. [6, 7] investigated the issues of query integrity and a solution was proposed. The solution allows users to verify executed queries in Cloud database server along with the additional support of flexible join and aggregate queries. Similarly, the solution proposed by M. Brzeźniak et al. [8] covers data key management, data encryption and data integrity which ensure high data security and access efficiency.

Cryptonite is a secure data repository solution proposed by A. Kumbhare et al. [9] which addresses availability requirements as well. It runs within Microsoft Azure and provides service APIs compatible with existing Cloud storage services.

Abdullatif Alzain et al. [10] extended the approach presented in [11], which provides the practical concept of secret sharing approach. There are three main layers in the architecture i.e. presentation Layer for HTTP server and end user's browser, management layer which consists of DBMS and database service provider and lastly, the Application layer where the actual application resides and runs.

Table 1 highlighted security challenges of DBaaS infrastructure along with their consequences and causes.

Table 1. Cloud DBaaS Security Challenges

No.	Security Challenge	Description
1	Availability	- Temporary and permanent unavailability cause service breakdown - DOS Attacks, natural disasters, equipment failure
2	Access Control Issues	- Physical, personnel and logical control missing on organization's internal and DBaaS Provider's employees - Increase development and analysis cost is incurred when user management and granular access control is implemented
3	Integrity Check	- Need to avoid modification of configuration, access and data files - Require accuracy and integrity of data
4	Auditing and Monitoring	- Configuration requirements change continuously - Important for avoiding failures, backup maintenance, configuration of auto fail-over mechanisms - Require stark network and physical device , expertise and relevant resources
5	Data Sanitization	Recovery of data by malicious sources if not properly discarded
6	Data Confidentiality	- Unencrypted data in memory, disk or in network may cause data breaches - Co-located application data is vulnerable to software bugs and errors in the Cloud - External organizations might also generate attacks
7	Data Replication and Consistency Management	Replications between multiple servers cause management as well as consistency issues
8	Network Security	Data flowing over the network (internet) is prone to hazardous

		circumstances and network performance issues. Possible network failure reasons are: misconfiguration, lack of resource isolations, poor or untested business continuity, disaster recovery plan, network traffic modification
9	Data Locality	- Compliance and data-security privacy laws prohibit movement of sensitive data among countries - Issues faced when no one takes responsibility of data in location independent data storage
10	Data Provenance	- Complexity and time sensitiveness in provenance metadata - Intensive computations involved in getting required history - Fast algorithms, auto logs are needed
11	Insider Threats	- Employees can tap into sensitive and confidential data - Strict supply chain management and assessment is required
12	Outside Malicious Attackers	- Malicious attacks by hackers - Difficulty in synchronizing data between users and reporting corruption - Absence of authentication, authorization and accounting controls - Poor key management for encryption and decryption

2. PROPOSED SECURE MODEL

Major concerns and issues in DBaaS have been discussed in the previous sections with emphasis on security challenges. It has been observed that, despite quality research on secure data outsourcing and data services for almost a decade, existing approaches on database encryption, authentication, digital signatures [12], contractual agreements etc. have not gained much success in operations. To date, there is minimal work done in the field of security and privacy of DBaaS as compared to traditional data storage. Different approaches for securing DBaaS are discussed under this section with assorted categories of confidentiality, privacy, integrity and availability.

State-of-the-art approaches mainly address generally adopted methods for their proposed models.. Those methods are:

Encryption based data security, which means hiding data content from service providers. **Private information retrieval**, which allows user to retrieve an item from the data server without revealing the content of that item. **Information distribution**, which is based on dispersing information instead of encrypting the data.

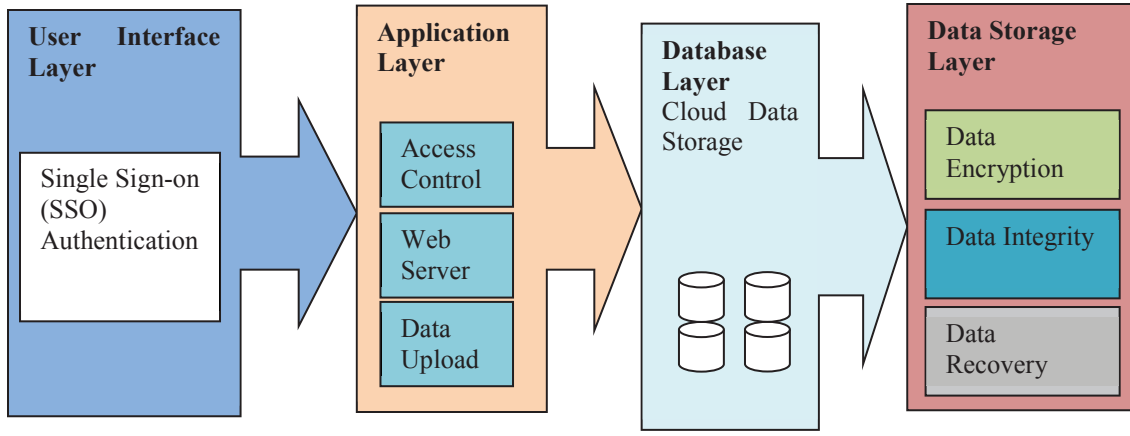


Figure 2. Secure Model for Cloud DBaaS

The model shown in figure 2 used Four-layer system structure, in which each floor performs its own duty to ensure that the data security of cloud layers.

The first layer: responsible for user authentication, it is one time password authentication. *User Interface Layer* used to access the service via internet. This allows users to easily utilize scalable and elastic database services available on Cloud infrastructure. The second layer: is used to access software services and storage space on the Cloud. As stated previously, consumers do not need to have hardware resources to avail these services.

for user's data upload, access control. Third layer provides efficient and reliable service of managing database residing in the Cloud. It allows reuse of the query statements residing in the storage, thus saving time for querying and loading data. Fourth layer is data storage layer where Data is encrypted and decrypted at storage and retrieval stages, respectively. Data integrity and data recovery is also provided at this layer.

Storage virtualization[13] is a part of data storage layer, which forms a pool of resources using multiple network storage devices. A central console is responsible for the management of the resources. Taking backups, archiving and recovering data are now more feasible and less time-consuming because of these available features. *Condition monitoring* Error detects significant changes that cause errors in storing and managing data. Storage layer also provides data management services, such as traffic analysis, compression, virtualization, security, and replication etc., through the use of tools, policies and processes. This layer also provides database upgrades when some major changes are made in the database structure or between different releases.

Our solution has three phases; Registration, Login, and Authentication.

2.1 Registration Phase

In the registration phase, user needs to register at the server by providing appropriate identification details. The server process user's data and issue a smartcard to the user. The procedure is as follows:

Let f be a one-way has function, and p be a very large prime such that $p = 2q + 1$ where q is also a large prime, also let δ be a

primitive element of $GF(p)$, which are all known public parameters. A random number $\eta \in [1, p-1]$, with $\gcd(\eta, p-1) = 1$, is selected by the system as its private key which is used to compute the public key $\lambda = \delta^\eta \bmod p$.

Now, due to the property of $\gcd(\eta, p-1) = 1$, the public key λ is also a primitive element of $GF(p)$.

Assuming that a new user U_i submits his identity ID_i to the system for registration, the system computes an image of the ID_i as (ID_i^*) and the signature (χ_i, y_i) of ID_i^* as

$$y_i = (ID_i^* - \alpha_i \chi_i) \eta^{-1} \bmod p-1$$

Where $\chi_i = \delta^{\alpha_i} \bmod p$, and α_i is randomly selected from $[1, p-1]$. We note here that due to ElGamal attack, our scheme is designed to signed the image of user identity ID_i^* , rather than directly signing the original user ID_i . Further, α_i should be used repeatedly to avoid uncovering the system's secret key η as a result of users collusion. It is clear here that y_i is U_i secret key generated from the system's secret key. Further, this can be a sort of shared secret between the system and the user.

2.2 Login Phase

At this phase, if user i wants to login, he inserts the smart card to the input device. Then send (ID_i, χ_i) to the device. Then the smart card will perform the following computations:

1. Selects an odd random number $v \in [1, p-1] \ni \gcd(v, p-1) = 1$, and then computes $\beta = \lambda^v \bmod p$, where λ is the public key of the system/server.
2. Computes another value: $Z = \beta^{y_i} \bmod p$ and sends Z to the server or system.

2.3 Authentication Phase

After receiving the authentication message Z , the remote server authenticates the login as follows:

1. Use Z and the image of U_i identity (i.e. ID_i^*) to verify that $\delta^{ID_i^*} = \chi_i^{y_i} Z^{v-1} \bmod p$
2. If the above condition holds, then the remote system generates a random number ρ and then sends the following to the smart card. Otherwise the request is rejected:

$$\{F(ID_i^* \oplus \rho)\chi_i\} \text{ or } \{F(ID_i^* \oplus \rho)k\}$$

Where k is a predetermined secret key shared between the server and the card. Similarly, the function F is an agreed secret function.

3. User i uses its secret key y_i or the shared key k to decrypt the message and recover ρ , i.e:

$$[\{F(ID_i * \oplus \rho)k\}]^{-1} = (ID_i \oplus \rho)$$

and compute:

$$K = \{F(\rho)\} \lambda \quad \text{or} \quad K = \{F(\rho)\} k$$

4. The smart card finally forwards K to the remote server. The system verifies whether $F^{-1}(K) = \rho$. If yes, the authentication process is completed. Otherwise, the request is rejected.

3. SECURITY ANALYSIS

To show the strength of our scheme, let's assume an intruder I knows Z , β , p , and $Z = \beta^{y_i} \bmod p$. Now trying to solve y_i from the information is always equivalent to computing the discrete logarithm problem over $GF(p)$, thus U_i 's secret key y_i will never be revealed to the public. Again, suppose an intruder impersonates U_i by developing v and V . Since $Z = \lambda^{y_i} \bmod p$ and $Z' = \lambda^{V y_i} \bmod p$, by knowing Z , v , and V , the intruder can derive as $Z' = Z^{v/V} \bmod p$ without knowing y_i . However, trying to compute v from β is equivalent to computing the discrete logarithm, again this attack is infeasible. Moreover, suppose ID_i is compromised, this information is not enough to derive either y_i , or χ_i since the values were derived using ID_i^* not just ID_i .

During authentication phase, the agreed secret function F and shared secret key k are used to protect the system against any guessing attack. Moreover, for additional security, multiple shared secret keys can be used, so that whenever an encrypted message is to be sent to the system or the user, a different secret key will be used. This will ensure that even exhausted search key by an intruder will not reveal the keys, since for any guessed value for one key, there is very likely to be a corresponding value of another key such that the message will appear correlated. Additionally, the system has an option to use public key system by using y_i to encrypt any message for U_i .

4. CONCLUSION

Data is possibly the most important asset a business has. Businesses today are trying hard to deal with the explosion of data and leverage it to their advantage. Database as a Service (DBaaS) is an increasingly popular Cloud service model, with attractive features like scalability, pay-as-you-go model and cost reduction that make it a perfect fit for most organizations. However, no extensive research work has been done which meticulously covers each and every aspect of DBaaS. Data storage security in Cloud is a domain which is full of challenges and is of paramount importance as customers do not want to lose their data at any cost. It is also a major hurdle in the way of adopting Cloud platform for storage services. Unfortunately, this area is still in its infancy and many research problems are yet to be identified. There is a need for effective strategies, proper measurements and methodologies to control this problem by having mature practices in the form of secure architectures to make DBaaS platform more secure, and ultimately, widely-adopted. In this paper, I have presented a security model for cloud DBaaS environments. I have described its components, discussed existing solutions and identified possible approaches to deal with different security issues related to the DBaaS.

5. FUTURE DIRECTIONS

Various techniques have been proposed for securing relational data model. However, these techniques need improvement in order to make them efficient and effective for DBaaS environment. Majority of such available solutions are based on traditional cryptographic techniques where the general idea is based on the outsourcing of

encrypted data by owner only. Publishers do not manage and encrypt data; rather encryption is performed by the owner before outsourcing. Since publishers do not receive keys for decrypting the data; therefore, it is recommended to devise such techniques which allow publishers to perform queries on the encrypted data.

Thus, after conducting a thorough study on DBaaS, it can be inferred that all the practical and widely adopted approaches for providing security in relational databases can also be adopted for Cloud DBaaS model (database outsourcing) after transforming them accordingly. Moreover, all extant solutions for mitigating security challenges have room to be improved and evaluated according to a benchmark for making them more mature, practical and reliable in order to provide secure Cloud database services.

6. REFERENCES

- [1] Oracle Corporation, (2011), *Database as a Service: Reference Architecture – An Overview*, 2011.
- [2] Krishna Kamal Kapa, Roger Lopez, (2012), *Database as a Service (DBaaS) using Enterprise Manager 12c*, Oracle Open World, 2012.
- [3] Luca Ferretti, Michele Colajanni, and Mirco Marchetti, (2012), *Supporting security and consistency for Cloud database, Cyberspace Safety and Security Lecture Notes in Computer Science* Volume 7672, pp. 179-193, 2012.
- [4] Cong Wang, Sherman S.M. Chow, Qian Wang, Member, Kui Ren, Wenjing Lou, (2013), *Privacy Preserving Public Auditing for Secure Cloud Storage*, IEEE TRANSACTIONS ON COMPUTERS, VOL. 62, NO. 2, pp. 362-375, 2013.
- [5] R.Nithiavathy, (2013), *Data Integrity and Data Dynamics with Secure Storage Service in Cloud*, Proceedings of the 2013 International Conference on Pattern Recognition, Informatics and Mobile Engineering, IEEE, pp. 125-130, 2013.
- [6] H. Hacigumus, B. Iyer, C. Li, S. Mehrotra, (2004), *Efficient Execution of Aggregation Queries over Encrypted Relational Databases*, In Proc. of the 9th International Conference on Database Systems for Advanced Applications (DASFAA'04), Jeju Island, Korea, pp. 125-136, 2004.
- [7] Qingji Zheng, Shouhuai Xu, Giuseppe Ateniese, (2012), *Efficient Query Integrity for Outsourced Dynamic Databases*, CCSW'12, Raleigh, North Carolina, USA, 2012.
- [8] Maciej Brzeźniak, Gracjan Jankowski, Michał Jankowski, Stanisław Jankowski, Tomasz Jankowski, Norbert Meyer, Rafał Mikołajczak, Adam Zawada and Sławomir Zdanowski, (2013), *National Data Storage 2: Secure Storage Cloud with Efficient and Easy Data Access*, 2013.
- [9] Alok Kumbhare, Yogesh Simmhan, Viktor Prasanna, (2012), *Cryptonite: A Secure and Performant Data* 2012 IEEE 5th International Conference on. IEEE, pp. 510-517, 2012.
- [10] Mohammed Abdullatif Alzain and Eric Pardede, (2011), *Using Multi Shares for Ensuring Privacy in Database-as-a-Service*, Proceedings of 44th Hawaii International Conference on System Sciences, pp. 1-9, 2011.
- [11] Divyakant Agrawal, Amr El Abbadi, Fatih Emekci, Ahmed Metwally, (2009), *Database Management as a Service: Challenges and Opportunities*, Data Engineering, ICDE'09. IEEE 25th International Conference on. IEEE, pp. 1709-1716, 2009.

- [12] R.C. Merkle,(1989),*A Certified Digital Signature*, Advances in Cryptology - CRYPTO '89, 9th Annual International Cryptology Conference, Santa Barbara, California, USA, Proceedings, Volume 435, pp. 218– 238, 1989.
- [13] Robert R. Moeller, (2013), *Executive's guide to IT Governance: Improving Systems Processes with Service Management, COBIT and ITIL* Wiley Corporate F&A, John Wiley & Sons, 2013.
- [14] HYDAC International, (2013), *Condition Monitoring for Efficient Life Cycle Cost Management*, 2013.



Kashif Munir has been in the field of higher education since 2002. After an initial teaching experience with courses in Stamford College, Malaysia for around four years, he later relocated to Saudi Arabia. He has been working as lecturer with King Fahd University for 9 years. He receives his BSc degree in Mathematics and Physics from Islamia University Bahawalpur,

Pakistan in 1999. He has MSc degree in Information Technology from University Sains Malaysia in 2001. He also obtained another MS degree in Software Engineering from University of Malaya, Malaysia in 2005. He earned his PhD Informatics from Malaysia University of Science and Technology, Malaysia in 2015. His research interests are in the areas of Cloud Computing Security software engineering, project management.